

Automotive Open Source Governance Monthly

Apr 23, 2026 5:00 PM - 6:00 PM (UTC)

Quick Recap

This meeting discussed updates to the SBOM (Software Bill of Materials) specification for the automotive industry. Keisuke Takase (Toyota Motor Corporation) reported on the progress of the automotive SBOM activity that started in February, and explained that the automotive SBOM specification had been revisited in order to resolve confusion arising from multiple standards and industry-specific business practices. Feedback received from participants covered considerations for OSS and VEX management, regulatory compliance, AI-driven development, and unique identifiers. A participant from one automotive manufacturer proposed recommending SPDX 2.3 and CycloneDX 1.6, suggesting that the industry should aim to migrate to SPDX 3.0 in the future as it matures. A participant from another automotive manufacturer raised challenges in VEX management and asked why the automotive SBOM does not include VEX information. It was confirmed that participants can provide feedback through GitHub and Google Docs.

Next Steps

- Ayumi: Coordinate with relevant members to investigate and compare in detail the differences and similarities between the Catena-X SBOM definition and the automotive SBOM specification discussed in this meeting, and report back in future meetings.
- Ayumi: Recruit members familiar with Catena-X and form a working group to compare and review the SBOM specifications.
- Ayumi: Continue discussion on recommended versions and scope of SBOM formats (SPDX, CycloneDX, etc.) based on input from participants and the community, and update the document as needed.
- Ayumi: Review how vulnerability management and VEX information should be handled within the SBOM, based on input from participants and the community, and refine the draft specification accordingly.
- Ayumi: Expand the document and specification to also cover SBOM management for AI/ML models and commercial/proprietary software, as well as the handling of unique identifiers (CPE, package URL, etc.).
- Ayumi: Continue accepting feedback through GitHub, Google Docs, and similar channels, and consolidate and reflect community comments, pull requests, and discussions.
- Relevant participant: Coordinate with Ayumi to provide mapping information between the automotive SBOM and the Catena-X SBOM specification, and join the discussion.
- Participant from one automotive manufacturer: Provide their company's input on recommended SBOM formats (SPDX, CycloneDX, etc.) via GitHub or other channels.
- Another participant: Provide input on cross-industry SBOM format recommendations.
- Ayumi: Continue expanding the document going forward to also cover new elements such as functional safety and vulnerability management.

Summary

Opening greetings among participants:

Participants exchanged greetings before the meeting started. Masato commented on the progress, and Keisuke noted that it would be the next day. Other participants also greeted one another.

Automotive SBOM update meeting:

Masato opened the meeting on the automotive SBOM (Software Bill of Materials) update and explained that feedback and requests had been received on the automotive SBOM discussion proposed by Ayumi and Keisuke two months earlier. The meeting is a cross-community meeting covering multiple communities (OpenChain, AGL, Eclipse, etc.) and is conducted in accordance with the antitrust policy. Keisuke attempted to share his screen but was temporarily interrupted due to a connection issue.

Update on automotive industry SBOM activity:

Keisuke provided an update on the SBOM (Software Bill of Materials) activity for the automotive industry at Toyota Motor Corporation. The activity aims to address challenges in implementing SBOMs in the automotive industry caused by multiple standards and industry-specific business practices, and is developing the automotive SBOM specification with reference to existing standards (such as SPDX and CycloneDX). At the meeting, comments were shared on its applicability not only to open source software management but also to the management of commercial and confidential software, its application to AI and machine learning models, vulnerability management, regulatory requirements, and the automation of coding through AI-driven development.

Discussion of the automotive SBOM concept and Catena-X:

Ayumi reported that European stakeholders had raised questions about the differences between the automotive SBOM concept and Catena-X, and announced that the team will begin studying the Catena-X specification next month. One participant shared that they had been involved as an engineer at an automotive manufacturer in defining the Catena-X SBOM exchange standard, and noted that bidirectional mapping is already available. Other participants and Masato asked about how to provide feedback, and it was confirmed that anonymous feedback can be submitted via GitHub and Google Docs.

Automotive SBOM formats and standardization:

One participant asked about the use of SPDX 2.3 and SPDX Lite for automotive, and Ayumi replied that any document format is acceptable for the automotive SBOM as long as it supports the automotive SBOM requirements. Masato explained that, since the automotive SBOM format is not defined, each OEM and supply chain should define the format that works best for them, and stated that the focus should be on process standardization rather than on the format itself.

Discussion on automotive SBOM best practices:

Masato shared best practices on handling the automotive SBOM and explained a continuous-update approach. A participant from one automotive manufacturer commented, as their company's view, that while standardization of data fields is important, recommendations on the SBOM format itself are also necessary, and recommended the use of SPDX 2.3 and CycloneDX 1.6. Ayumi responded that SPDX Lite is currently widely used in Japan and that restricting it would be difficult, and invited discussion on the possibility of recommending the use of SPDX only, or specific versions of SPDX and CycloneDX.

Discussion on automotive SBOM vulnerability management:

A participant from another automotive manufacturer raised a discussion on the automotive SBOM document and pointed out challenges around VEX (vulnerability) management. Ayumi explained why automotive systems do not include vulnerability information in the SBOM, and agreed to continue the discussion on how security information should be handled. The earlier participant from an automotive manufacturer noted that the industry is not yet accustomed to providing SBOMs and that, while both CycloneDX and SPDX are currently being recommended, the long-term aim is to migrate to SPDX 3.0. Another participant emphasized the need to define fields that cover various areas such as open source compliance.

